FUNDAÇÃO ESCOLA DE COMÉRCIO ÁLVARES PENTEADO – FECAP
CENTRO UNIVERSITÁRIO FECAP – CAMPUS LIBERDADE
CURSO DE BACHARELADO EM CIÊNCIA DA COMPUTAÇÃO

GABRIEL CARVALHO MOTA
GUILHERME DE LIMA SIQUEIRA
RODRIGO LUIZ MENEZES DOS REIS
VITORIA LETICIA MACIEL DA SILVA

SMART TENNIS ARENA (TOBIAS): PLANO DE RESPOSTAS AOS RISCOS DE CIBERSEGURANÇA E RELATÓRIO DE EVOLUÇÃO

análise comparativa de vulnerabilidades e plano de ação da entrega 2

SÃO PAULO
2026

RESUMO

Este trabalho apresenta o Plano de Respostas aos Riscos de Cibersegurança e o Relatório de Evolução Técnica da solução IoT Smart Tennis Arena (Tobias), desenvolvida no curso de Ciência da Computação da Fundação Escola de Comércio Álvares Penteado (FECAP). Tomando como base a análise de vulnerabilidades documentada na Entrega 1 — que evidenciou a ausência crítica de parada de emergência (RF22), a vulnerabilidade a ataques de negação de serviço (DoS) por conexão incondicional, a inexistência de desafio criptográfico no emparelhamento BLE e a transmissão telemétrica em texto plano —, este relatório detalha as respostas técnicas implementadas na Entrega 2. As ações cobrem o firmware embarcado no ESP32, o aplicativo móvel em Flutter e a API em nuvem (Microsoft Azure). Dentre as soluções implementadas, destacam-se a resolução estrita do RF22 através da criação de característica BLE RX para recepção dos comandos STOP, CANCELAR, RESET, PAUSAR e RETOMAR, acompanhados de corte acústico instantâneo no DFPlayer Mini e desligamento de atuadores; a criação do modo Standby Silencioso para blindagem contra DoS acústico; a padronização das mensagens em JSON tipado com identificador único temporal (id_lance) e auditoria de pontuação no backend; o controle de acesso baseado em papéis (RBAC) com isolamento do modo simulador exclusivamente para administradores; a sincronização temporal de cinco segundos com o áudio 0500.mp3 para eliminação de falsos erros de timeout; e a estabilização da alimentação em 5V com bateria Li-Ion 3,7V e conversor Step-Up, assegurando cinco a seis horas de autonomia contínua. Demonstra-se a mitigação eficaz dos riscos prioritários e o alinhamento com as normas de segurança em IoT.

Palavras-chave: Cibersegurança. Internet das Coisas. Bluetooth Low Energy. Parada de Emergência. Gestão de Riscos.

SUMÁRIO

1 INTRODUÇÃO 4

1.1 Contextualização e Escopo da Entrega 2 4

1.2 Metodologia e Tríade de Segurança (CIA) 4

2 TABELA DE RESPOSTAS AOS RISCOS 5

3 DETALHAMENTO DAS ESTRATÉGIAS DE RESPOSTA 7

3.1 Estratégias para Ameaças (Riscos Negativos) 7

3.1.1 Prevenir (Evitar) 7

3.1.2 Transferir 7

3.1.3 Mitigar 7

3.1.4 Aceitar 7

3.2 Estratégias para Oportunidades (Riscos Positivos) 7

4 ANÁLISE COMPARATIVA DE AVANÇOS: ENTREGA 1 VS. ENTREGA 2 9

4.1 Confronto Direto de Vulnerabilidades 9

4.2 Síntese Evolutiva da Arquitetura 9

5 GOVERNANÇA, MONITORAMENTO E REVISÃO CONTÍNUA 10

5.1 Pipeline de Testes Automatizados e Auditoria Contínua 10

5.2 Ciclo de Revisão e Planejamento para a Entrega 3 10

1 INTRODUÇÃO

O projeto Smart Tennis Arena consiste no desenvolvimento de uma plataforma integrada de Internet das Coisas (IoT) voltada à prática desportiva gamificada de tênis. O ecossistema articula um alvo físico móvel e autoportante (o boneco mecatrônico apelidado de Tobias), sensores inerciais acoplados, um módulo de controle microcontrolado baseado no processador ESP32, um aplicativo móvel em Flutter e serviços de retaguarda hospedados em nuvem pública (Microsoft Azure).

No âmbito da unidade curricular de Redes de Computadores e Cibersegurança, a integridade da comunicação e a segurança física dos usuários representam premissas obrigatórias de engenharia. Na primeira iteração do projeto (Entrega 1), uma revisão técnica do código-fonte do firmware diagnosticou vulnerabilidades severas, com destaque para a ausência de autenticação e emparelhamento seguro BLE (V01), risco iminente de sequestro de conexão (V02), tráfego de dados telemétricos em formato de texto livre sem validação (V03) e, prioritariamente, a inexistência de um mecanismo de parada segura (V04), em descumprimento direto do requisito funcional RF22.

1.1 Contextualização e Escopo da Entrega 2

A Entrega 2 marca a transição de um módulo embarcado pontual para uma arquitetura integrada em camadas completas. O escopo abrange o desenvolvimento do firmware definitivo em C++ para o microcontrolador ESP32 com suporte ao protocolo Nordic UART Service (NUS); o aplicativo móvel oficial em Flutter com gestão de estado, fila offline e regras de acesso; a infraestrutura de backend em FastAPI provisionada na nuvem corporativa Microsoft Azure; e a reestruturação da alimentação elétrica para garantia de disponibilidade operacional contínua.

1.2 Metodologia e Tríade de Segurança (CIA)

A condução deste plano baseia-se na metodologia de gestão de riscos do PMBOK integrada às diretrizes do OWASP IoT Top 10 e da norma NIST SP 800-121 Rev. 2. A análise estrutura-se em torno dos três pilares da segurança da informação:

- **Confidencialidade:** proteção das informações de desempenho dos praticantes e dos registros de autenticação, impedindo espionagem passiva ou acesso não autorizado;
- **Integridade:** garantia de que as pontuações esportivas, contagens de acertos e medições angulares não sejam forjadas ou adulteradas durante o tráfego sem fio ou no armazenamento local;
- **Disponibilidade:** asseguramento da operabilidade contínua do alvo físico e da aplicação, prevenindo travamentos de software, reinicializações por queda de tensão e ataques locais de negação de serviço.

2 TABELA DE RESPOSTAS AOS RISCOS

A Tabela 1 reúne o mapeamento sistemático dos riscos e oportunidades identificados no projeto Smart Tennis Arena, estabelecendo as estratégias formais adotadas, as ações concretas implementadas na Entrega 2, os agentes responsáveis e o estado atual de resolução.

Tabela 1 – Resumo do Plano de Respostas aos Riscos do Projeto (continua)

ID Risco	Descrição do Risco	Prioridade	Estratégia	Ações Específicas Implementadas (Entrega 2)	Resp.	Status
RISC-SAF-001 (Ref. V04)	**Inexistência de Parada Segura (RF22):** loop infinito no firmware sem canal de recepção, incapaz de interromper áudio, LEDs ou leituras em caso de falha física ou operacional.	Crítica	Prevenir (Evitar)	1. Criação de característica BLE RX com callback MyRxCallbacks. 2. Implementação dos comandos STOP, CANCELAR, RESET, PAUSAR e RETOMAR. 3. Corte de áudio instantâneo no DFPlayer (0x16) e retorno ao repouso. 4. Teardown seguro no app com unawaited(_gravador.encerrar()).	Firmware / Mobile	Concluído
RISC-DAT-002 (Ref. V03)	**Telemetria em Texto Plano e Forjamento:** dados transmitidos em string aberta ("IMPACTO: 35G"), facilitando captura por sniffing e injeção de lances falsos.	Alta	Mitigar	1. Adoção de formato JSON (RFC 8259) tipado. 2. Identificador único id_lance com carimbo temporal e tempo relativo t_ms. 3. Auditoria e recálculo centralizado de notas e KOs no Backend Azure. 4. Tráfego móvel-nuvem cifrado com HTTPS/TLS 1.3.	Backend / Mobile	Concluído
RISC-DOS-003 (Ref. V02)	**Sequestro de Ligação e DoS Local:** conexão não autenticada bloqueava o pareamento legítimo e qualquer balanço disparava áudios repetidos no volume máximo.	Alta	Mitigar	1. Criação do Standby Silencioso (MODO_AGUARDANDO): boneco não processa impactos nem emite som antes de comando formal. 2. Filtro no app conectando unicamente ao identificador TOBIAS, rejeitando dispositivos clones ou simulados.	Firmware / Mobile	Concluído
RISC-AUT-004 (Ref. V01)	**Acesso Não Autorizado e Vazamento:** ausência de autenticação expondo métricas dos atletas e informações de infraestrutura da rede.	Alta	Mitigar	1. Autenticação JWT com tokens Bearer HMAC-SHA256 no Backend. 2. Ocultação do endereço de IP do servidor na tela de login. 3. Isolamento da fila offline local no SQLite pelo usuarioId autenticado, impedindo sequestro de dados entre usuários.	Backend / Mobile	Concluído
RISC-SIM-005 (Novo E2)	**Fraude Esportiva via Simulador:** opção de simulação aberta permitindo que usuários forjassem pontuações no ranking sem utilizar o boneco real.	Alta	Prevenir (Evitar)	1. Aplicação de RBAC (Role-Based Access Control) com método AuthStore.ehAdmin(). 2. Remoção do simulador para atletas comuns nas telas de seleção e pareamento, restringindo-o a administradores.	Mobile / Backend	Concluído

Fonte: Elaborado pelos autores (2026).

Tabela 1 – Resumo do Plano de Respostas aos Riscos do Projeto (conclusão)

ID Risco	Descrição do Risco	Prioridade	Estratégia	Ações Específicas Implementadas (Entrega 2)	Resp.	Status
RISC-CON-006 (Novo E2)	**Dessincronização e Falso Timeout:** início imediato do treino disparava timeout de erro enquanto o áudio de abertura tocava no alto-falante.	Média	Mitigar	1. Contagem regressiva visual de 5s no aplicativo sincronizada com o envio de início. 2. Firmware congela detecção de impactos e timeouts durante os 5000ms da introdução (0500.mp3). 3. Janela do lance 1 inicia rigorosamente após a introdução.	Firmware / Mobile	Concluído
RISC-RCE-007 (Novo E2)	**Sobrecarga Mecânica por Intervalos Curtos:** configuração de intervalos inferiores ao retorno pendular provocava colisões e leituras inconsistentes.	Média	Prevenir (Evitar)	1. Parametrização no app limitando o intervalo entre 3s e 10s. 2. Trava física no firmware com INTERVALO_MINIMO_MS = 3000, corrigindo automaticamente qualquer parâmetro inferior recebido.	Mobile / Firmware	Concluído
RISC-PWR-008 (Hardware)	**Instabilidade Elétrica e Brownout:** alimentação original em 7,4V causava superaquecimento no regulador do ESP32 e risco de reinicializações espúrias.	Média	Prevenir (Evitar)	1. Reconfiguração para célula Li-Ion de 3,7V (3000mAh) com conversor Step-Up estabilizado em 5,0V. 2. Autonomia garantida de 5 a 6 horas contínuas de treino. 3. Supressão de percentual fixo falso de bateria na interface do aplicativo.	Hardware / Mobile	Concluído
OPP-001 (Oportunidade)	**Otimização de Canal por Relatório Agregado:** oportunidade de reduzir tráfego aéreo e consumo energético compilando métricas no alvo.	Alta	Explorar	1. Firmware calcula médias, maior ângulo e total de KOs na memória local. 2. Envio de relatório consolidado TREINO_CONCLUIDO ao término do treino. 3. Redução de 75% na sobrecarga do espectro de radiofrequência de 2,4 GHz.	Firmware / Redes	Concluído
OPP-002 (Oportunidade)	**Resiliência e Treino em Ambientes Offline:** viabilização de treinos em quadras desprovidas de sinal de internet ou cobertura móvel.	Alta	Melhorar	1. Implementação de persistência local relacional em SQLite (FilaSessoes). 2. Sincronização automática em segundo plano via Sincronizador ao restabelecer rede. 3. Idempotência no processamento de lotes pendentes na nuvem.	Mobile / Cloud	Concluído

Fonte: Elaborado pelos autores (2026).

3 DETALHAMENTO DAS ESTRATÉGIAS DE RESPOSTA

O gerenciamento dos riscos no ecossistema Smart Tennis Arena articula ações proativas e reativas, divididas conforme a tipologia da incerteza (ameaças ou oportunidades).

3.1 Estratégias para Ameaças (Riscos Negativos)

3.1.1 Prevenir (Evitar)

A prevenção consiste na eliminação integral da causa-raiz da vulnerabilidade por meio de alterações estruturais no código ou na arquitetura de hardware:

- **Parada Segura (RISC-SAF-001):** a criação do canal de comando BLE RX com processamento de emergência extinguiu o risco de perda de controle físico. O comando `STOP` cessa imediatamente os atuadores sem depender da finalização de ciclos de leitura;
- **Fraude Esportiva (RISC-SIM-005):** a exclusão do modo simulador das interfaces acessíveis a praticantes comuns impediu a inserção de treinos artificiais no ranking;
- **Colisão Mecânica de Estados (RISC-RCE-007):** a fixação de piso rígido em 3.000 ms impossibilita que o atleta configure lances em cadência mais rápida que o tempo de estabilização do pêndulo.

3.1.2 Transferir

A transferência envolve repassar a responsabilidade de mitigação e disponibilidade a terceiros especializados:

- **Infraestrutura e Proteção em Nuvem:** a hospedagem dos serviços de autenticação, banco de dados e APIs foi transferida para a plataforma de computação em nuvem **Microsoft Azure**, valendo-se de acordos formais de nível de serviço (SLA), mitigação nativa de ataques distribuídos de negação de serviço (DDoS) e criptografia de tráfego com certificados TLS gerenciados.

3.1.3 Mitigar

A mitigação foca em reduzir a probabilidade e o impacto de eventos adversos a parâmetros controláveis:

- **Sequestro de Conexão e Poluição Sonora (RISC-DOS-003):** a criação do modo `MODO_AGUARDANDO` silencia completamente o alvo mecatrônico até o recebimento de comando autenticado, neutralizando disparos sonoros decorrentes de perturbações externas;
- **Proteção de Dados do Treino (RISC-DAT-002 e RISC-AUT-004):** a estruturação dos dados em JSON e o isolamento local no SQLite pelo identificador de usuário logado (`usuarioId`) mitigam adulterações e contaminação de dados entre atletas;
- **Dessincronização Temporal (RISC-CON-006):** a temporização controlada de 5 segundos (`emIntroTreino`) elimina a ocorrência de penalidades falsas de tempo durante a reprodução do áudio de introdução.

3.1.4 Aceitar

A aceitação reconhece a existência do risco sem modificar o fluxo crítico, subdividindo-se em:

- **Aceitação Ativa:** inserção de temporizador de contingência de 1.500 ms no aplicativo para comandos de pausa; caso o microcontrolador não confirme o pacote no prazo devido a interferências no espectro RF, a interface reverte a indicação visual sem bloquear o usuário;
- **Aceitação Passiva:** a ausência de encriptação na camada de enlace BLE (Security Manager Protocol) é aceita provisoriamente nesta entrega, compensada pela validação das regras esportivas e cálculo centralizado na nuvem.

3.2 Estratégias para Oportunidades (Riscos Positivos)

- **Explorar (OPP-001):** aproveitamento da capacidade de processamento do ESP32 para consolidação local dos relatórios de sessão, otimizando a transmissão e poupando bateria;
- **Melhorar (OPP-002):** implementação de persistência relacional offline-first com SQLite no dispositivo móvel, viabilizando treinos ininterruptos em quadras sem conectividade externa.

4 ANÁLISE COMPARATIVA DE AVANÇOS: ENTREGA 1 VS. ENTREGA 2

Esta seção estabelece o confronto direto entre as fragilidades apontadas no Relatório de Vulnerabilidades da Entrega 1 e os avanços consolidados na Entrega 2.

4.1 Confronto Direto de Vulnerabilidades

A Tabela 2 sintetiza a evolução técnica registrada entre as duas iterações do projeto:

Tabela 2 – Confronto de Vulnerabilidades entre as Entregas 1 e 2

Item / Vulnerabilidade	Diagnóstico na Entrega 1	Implementação na Entrega 2	Grau de Resolução
V04 - Parada Segura (RF22)	Microcontrolador em laço ininterrupto sem interrupções de controle; sem canal BLE RX; impossibilidade de cessar reprodução de áudio no DFPlayer ou interromper leituras físicas.	Criação de característica BLE RX com comandos STOP, CANCELAR, RESET, PAUSAR e RETOMAR. Invocação direta da rotina pararAudio() (comando 0x16) e retorno ao Standby Silencioso. Execução automática de parada no encerramento de tela do aplicativo via unawaited(_gravador.encerrar()).	Resolvido integralmente (100% de conformidade com RF22)
V02 - Sequestro de Ligação e DoS	Advertising interrompido indiscriminadamente ao conectar; conexões não autorizadas bloqueavam o canal e qualquer toque no boneco disparava áudio em volume máximo.	Implementação da arquitetura de Standby Silencioso (MODO_AGUARDANDO): atuação inerte até recepção de ordem válida. O aplicativo móvel aplica filtro no escaneamento conectando exclusivamente ao periférico anunciado com o identificador TOBIAS.	Mitigado eficazmente (90% de redução de impacto)
V03 - Telemetria em Texto Plano	Telemetria transmitida como texto livre concatenado ("IMPACTO FORTE: 35.0G"), suscetível a falsificação e injeção sem controle de consistência temporal.	Transição para JSON tipado com campos id_lance único temporal e carimbo relativo t_ms. Recálculo e auditoria rigorosa de pontuação e KOs realizados pelo Backend em nuvem, rejeitando lances fraudados.	Mitigado satisfatoriamente (85% de controle lógico)
V01 - Ausência de Autenticação BLE	Servidor GATT permitia conexão e leitura direta de telemetria por qualquer aparelho na proximidade sem PIN ou credencial de acesso.	Implementação de autenticação JWT Bearer no Backend, isolamento de treinos no SQLite móvel por usuarioId autenticado e ocultação de endpoints da infraestrutura nas interfaces do usuário.	Evolução arquitetural (75% de compensação em profundidade)

Fonte: Elaborado pelos autores (2026).

4.2 Síntese Evolutiva da Arquitetura

O Quadro 1 sintetiza as mudanças de paradigma operacional introduzidas na Entrega 2:

Quadro 1 – Síntese Comparativa da Arquitetura de Segurança

CENÁRIO ENTREGA 1 (INSEGURO)	CENÁRIO ENTREGA 2 (AUDITADO E SEGURO)
• Atuação sonora descontrolada a qualquer balanço ou choque no repouso; • Inexistência de comando de emergência para interromper o funcionamento; • Telemetria transmitida em formato aberto de texto puro; • Acesso irrestrito ao modo simulador por qualquer usuário; • Exposição explícita do endereço de rede do servidor na interface móvel.	• Standby Silencioso absoluto em repouso, imune a ruídos mecânicos; • Parada de emergência RF22 via software e corte de atuadores por comando; • Mensagens formatadas em JSON com identificadores temporais anti-replay; • Modo simulador restrito exclusivamente a perfis administradores (RBAC); • Criptografia HTTPS/TLS na nuvem Azure e persistência offline isolada.

Fonte: Elaborado pelos autores (2026).

5 GOVERNANÇA, MONITORAMENTO E REVISÃO CONTÍNUA

A eficácia de um plano de respostas aos riscos depende de rotinas contínuas de inspeção, testes de validação e refinamento periódico.

5.1 Pipeline de Testes Automatizados e Auditoria Contínua

A qualidade e a segurança lógica do código-fonte foram submetidas a verificações automatizadas sistemáticas durante o ciclo de desenvolvimento da Entrega 2:

- **Análise Estática de Código:** emprego sistemático do analisador estático do Flutter (`flutter analyze`) com tolerância zero a falhas ou avisos nos módulos de gravação e gerenciamento de estado (`em_andamento_screen.dart`, `gravador_sessao.dart`);
- **Suíte de Testes Automatizados de Integração:** execução de suíte abrangendo 21 testes automatizados (testes de layout adaptativo, validação de transição de estados de pausa e retomada, persistência e integridade em banco SQLite e verificação de comportamento em cenários de ausência de conectividade de rede);
- **Auditoria Centralizada de Consistência no Backend:** implementação de rotina de verificação no momento do recebimento das sessões pela API na nuvem Azure, na qual os intervalos temporais entre lances e os ângulos registrados são conferidos e recalculados, descartando dados corrompidos.

5.2 Ciclo de Revisão e Planejamento para a Entrega 3

Este plano é revisado quinzenalmente pelos responsáveis técnicos do projeto. Para a terceira e última iteração (Entrega 3), estão estabelecidas as seguintes metas de aprimoramento de segurança:

1. **Implementação de BLE Security Manager Protocol (SMP):** introdução de rotina de emparelhamento com chave numérica pré-compartilhada (PIN de 6 dígitos) e encriptação de enlace por cifra AES-128 CCM, coibindo a interceptação direta no meio físico;
2. **Assinatura Digital de Lances:** estudo de viabilidade para geração de código de autenticação de mensagem (HMAC) no microcontrolador ESP32 para cada pacote de impacto emitido;
3. **Conformidade com a Legislação de Proteção de Dados:** adequação formal dos termos de consentimento e retenção de telemetria aos ditames da Lei Geral de Proteção de Dados Pessoais (LGPD).